

When Core-Network Elements Become Reachable: Field-Level Exploitability Analysis in Diameter

Anonymous Authors

Abstract—The increasing exposure of cellular core-network elements to public networks has turned Diameter signaling interfaces into a practical attack surface. While modern large language models (LLMs) show promise for protocol exploitability analysis, we observe that their judgments on Diameter often become unreliable, as they may deviate from the tacit analysis discipline followed by security experts and prematurely reach conclusions without considering the complete protocol evidence needed for sound analysis. To address this challenge, we present LENS, an LLM-based system for reliable field-level Diameter exploitability analysis. Rather than directly asking LLMs whether a Diameter field is exploitable, LENS guides LLMs using both the exploitability-analysis discipline and the protocol evidence needed for exploitability analysis. To obtain such guidance, LENS leverages LLMs to infer analysis discipline from existing exploit writeups and evidence-collection guidance from exploitability-analysis failures. The inferred guidance enables LENS to systematically collect protocol evidence, assess the exploitability of target Diameter fields, and generate proof-of-concept (PoC) attacks when applicable.

Our experiments show that LENS performs reliable exploitability analysis across four LLMs and repeated runs, achieving mean recall of 94.00% to 98.00%, precision of 78.73% to 88.94%, and accuracy of 84.00% to 92.00%. Using LENS, we find that exploitability is surprisingly widespread in Diameter: more than 25% of field paths in the S6a and Cx interfaces are exploitable under the considered threat model. Building on these protocol-level findings, we further assess their impact on practical implementations and uncover 95 previously unknown vulnerabilities, including 17 in open-source EPC/IMS implementations and 78 in commercial deployments. These vulnerabilities lead to severe security consequences, such as service disruption, information leakage, subscriber tracking, and accelerated battery depletion. Furthermore, our results demonstrate the strong generalizability of LENS. Applying LENS to 16 additional protocols spanning cellular, network, industrial, and host-internal systems uncovers 118 previously unknown vulnerabilities.

1. Introduction

Cellular core networks have long been treated as trusted internal environments. Recent research and security reports [1], [2], [3], however, show that this assumption does not always hold in practice. 4G core-network elements have increasingly been found reachable from public networks,

and existing works further demonstrate that attackers can exploit such exposure through crafted signaling messages, potentially triggering unintended core-network operations and security consequences. While existing works provide only isolated attack cases [2], public exposure of core-network elements is now a practical reality. As a result, systematically understanding the broader security risks introduced by exposed core-network signaling interfaces becomes increasingly important.

Among core-network signaling protocols, the Diameter protocol is a particularly security-critical target [4], [5]. Diameter is used by core-network elements to exchange and update subscriber information, supporting critical network functions such as subscriber authentication, service access, and billing. Crafting Diameter messages with manipulated field values may therefore cause core-network elements to make incorrect security-sensitive decisions, potentially affecting subscriber services and triggering unintended core-network behavior. However, systematically determining whether a Diameter field is actually exploitable is highly challenging. A Diameter field that appears harmless within its local message context may later influence security-sensitive behavior after its value is processed and propagated across multiple protocol procedures and core-network elements. In many cases, understanding such effects requires correlating protocol logic scattered across multiple and complex 3GPP specifications, making exploitability analysis difficult even for domain experts. Moreover, Diameter messages contain hundreds of fields. Systematically analyzing their exploitability manually is therefore impractical, and automated analysis becomes necessary.

Given the capabilities of modern large language models (LLMs), a natural question is whether they are already sufficient for this task. Encouragingly, our preliminary study shows that even directly asking LLMs whether a Diameter field is exploitable already works surprisingly well in some cases: LLMs can not only correctly judge whether a Diameter field is exploitable, but also generate working proof-of-concept (PoC) exploits. This suggests that modern LLMs are already capable of performing non-trivial exploitability analysis for Diameter protocols. However, such capability remains highly unstable in practice. The direct use of LLMs still fails on more than half of the cases in our preliminary experiments. Upon closer examination, we find that these incorrect judgments mainly arise from two issues. First, LLMs may drift beyond the tacit analysis discipline commonly followed by security experts during

exploitability analysis. For example, LLMs may assume attacker capabilities that experts would normally rule out in practice, such as assuming that attackers can obtain long-term shared secrets between trusted core-network components. Such drift can easily lead to incorrect exploitability conclusions. Second, LLMs may prematurely make judgments without considering all protocol evidence relevant to exploitation. For example, LLMs may overlook how crafted field values later influence subsequent core-network operations, even when such information already exists in 3GPP specifications. Without considering sufficient protocol evidence, LLMs can easily make incorrect judgments.

These observations suggest a promising direction for using LLMs to perform reliable Diameter exploitability analysis: explicitly providing LLMs with the *tacit exploitability-analysis discipline* used by security experts and the *protocol evidence* relevant to exploitation. However, obtaining both remains highly challenging. For tacit analysis discipline, it is nearly impossible to force experts to fully write it out. This challenge resembles Polanyi’s paradox [6]: “*we know more than we can tell*,” conveying that fully articulating tacit expert knowledge into explicit rules is difficult for humans. For protocol evidence, even experts usually do not know all relevant information upfront. In practice, exploitability analysis is typically a failure-driven process with iterative evidence seeking: analysts continuously search for additional protocol information from 3GPP specifications to understand why current exploit attempts fail, or determine whether a target field is exploitable or not.

Our method. Facing these challenges, our method leverages LLMs to infer both tacit analysis discipline and protocol evidence for Diameter exploitability analysis. For tacit analysis discipline, given LLMs’ strong abstraction and induction capabilities [7], we ask LLMs to infer the tacit analysis discipline from existing exploit writeups. This is possible because exploit writeups naturally reflect such discipline: the exploitability analysis and PoC construction described in these writeups are produced under the discipline’s guidance. For protocol evidence, given LLMs’ reflective reasoning capabilities [8], [9], we let LLMs emulate how human experts infer missing protocol evidence from failed exploit attempts. Specifically, we ask LLMs to analyze inconsistencies between incorrect exploit writeups generated by LLMs and corresponding ground-truth ones, and further infer what protocol evidence should be considered for LLMs to make correct exploitability judgments. Here, rather than asking LLMs to infer the exact missing protocol evidence for a specific case, our method asks LLMs to infer general guidance for collecting protocol evidence, which can be applied to any target field.

Building on this design, we propose LENS, a carefully designed LLM-based system for reliable field-level Diameter exploitability analysis. Given a target Diameter field, LENS first uses the LLM-inferred evidence-collection guidance to collect protocol evidence associated with the target field. It then provides the collected evidence, together with the inferred tacit analysis discipline, as guidance for

LLMs to perform exploitability analysis. When the target field is determined to be exploitable, LENS further generates corresponding PoCs. These PoCs are also used for security-impact assessment of representative core-network implementations in our controlled testing environment.

Results. We evaluate LENS on a manually labeled dataset of Diameter fields and find that it performs reliable exploitability analysis across four LLMs and repeated runs, achieving mean recall of 94.00% to 98.00%, mean precision of 78.73% to 88.94%, and mean accuracy of 84.00% to 92.00%. Using LENS, we then perform the first systematic field-level exploitability analysis of the Diameter protocol. The results reveal widespread field-level exploitability: among 766 analyzed fields in the S6a and Cx interfaces, 204 fields (26.63%) are exploitable at the protocol level under our threat model, indicating that over one quarter of the analyzed Diameter fields can be exploited once core-network elements become reachable. Remarkably, 196 of them have not been previously reported. These weaknesses are not merely protocol-level findings. Through implementation-level assessment on representative EPC/IMS implementations, we uncover 95 previously unknown vulnerabilities, including 17 in open-source implementations and 78 in commercial implementations. These vulnerabilities enable severe security consequences affecting real subscribers, including persistent service disruption, information leakage, subscriber tracking, and accelerated battery depletion. Finally, we demonstrate that the methodology behind LENS generalizes beyond Diameter. Using LENS to analyze 16 additional widely used protocols spanning diverse domains, such as VoIP communication, Internet routing, and IoT messaging, uncovers 279 protocol-level PoC candidates, including 150 previously unreported ones, of which 118 are further confirmed in real open-source implementations.

Contribution. This paper makes the following contributions:

- *New technique.* We present LENS, an LLM-based methodology that infers exploitability-analysis discipline and evidence-collection guidance for reliable field-level protocol exploitability analysis.
- *New finding.* We conduct the first systematic field-level exploitability analysis of the Diameter S6a and Cx interfaces, revealing that over one quarter of the analyzed fields are exploitable once core-network elements become reachable and uncovering 95 previously unknown vulnerabilities in open-source and commercial EPC/IMS implementations.

2. Background

Diameter protocol. Diameter is a signaling protocol family widely used in 4G core networks to support communication among network elements (NEs) [5]. Different Diameter-based interfaces are responsible for different network functions. For example, the S6a interface uses Diameter signaling between the Mobility Management Entity (MME) and the Home Subscriber Server (HSS) to support subscriber management and authentication, while the Cx interface uses Diameter signaling between IP Multimedia Subsystem

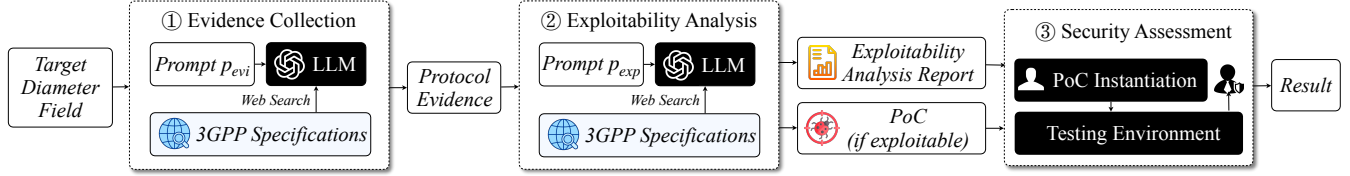


Figure 1: Workflow of LENS.

(IMS) entities and the HSS for IMS service control (e.g., voice call services). Through these interfaces, NEs use Diameter messages to request information, deliver instructions, or make control-plane decisions. In particular, the semantics of Diameter messages are determined by the values of message fields defined in 3GPP technical specifications. Given a specific interface and message type, setting individual or combined field values instructs NEs to perform different operations. In this work, we focus on the S6a [10] and Cx [11], [12] interfaces, as they are representative Diameter-based interfaces in 4G core networks.

Threat model. We consider the following threat model: a victim NE exposes a Diameter interface reachable from public networks and does not enable TLS protection for incoming Diameter connections; an attacker can impersonate a legitimate NE, establish Diameter connections with exposed NEs, and send crafted Diameter messages with manipulated field values to influence subsequent network operations. This threat model actually exists in real-world deployments, according to recent research and security reports [1], [2], [3], [13], [14]. In addition, through our communications, mobile network operators and core-network equipment vendors further confirmed that exposed internal NEs and disabled TLS protection are not uncommon in commercial environments due to maintenance and performance considerations.¹

3. Design

3.1. Overview

LENS aims to enable reliable LLM-based field-level Diameter exploitability analysis. To achieve this goal, LENS is designed to provide LLMs with two types of information, which are often overlooked when directly asked whether a Diameter field is exploitable: (1) the *tacit exploitability-analysis discipline* used by security experts and (2) the *protocol evidence* needed for exploitability analysis and PoC construction.

However, as discussed in the Introduction, obtaining such information is challenging, even for security experts. To address this challenge, our design leverages LLMs to derive such information. For exploitability-analysis discipline, we ask LLMs to infer the discipline from existing exploit writeups. For protocol evidence, we ask LLMs to analyze the inconsistencies between incorrect LLM-generated exploit writeups and the corresponding ground-truth ones, and then infer how protocol evidence should be collected.

1. We omit the identities of the involved operators and vendors for confidentiality reasons.

Both inferred results are encoded into two prompts, p_{exp} and p_{evi} : p_{exp} encodes exploitability-analysis discipline, and p_{evi} encodes evidence-collection guidance. Notably, the two prompts are not independent, as inferring either prompt requires information provided by the other. LENS therefore refines the two prompts jointly.

Once the two prompts are prepared, LENS uses them to analyze previously unanalyzed Diameter fields. Given a target Diameter field, LENS first performs evidence collection using p_{evi} to gather protocol evidence associated with the target field across the 3GPP specification corpus. The collected evidence is then provided together with the target field to p_{exp} for exploitability analysis, which generates an exploitability analysis report and a corresponding PoC when the target field is determined to be exploitable. Finally, the generated PoCs are used by LENS for security-impact assessment. Specifically, the generated PoCs are executed against representative core-network implementations in our controlled testing environment to examine whether these implementations are affected in the manner predicted in the exploitability analysis report. Fig. 1 illustrates the overall workflow of LENS.

The remainder of this section details how LENS infers exploitability-analysis discipline and evidence-collection guidance, jointly refines the resulting prompts, and performs security-impact assessment using the generated PoCs.

3.2. Exploitability-Analysis Discipline Inference

Diameter exploitability analysis is typically performed under a tacit analysis discipline used by security experts. It guides how exploitability conclusions are reached and how PoCs are constructed. However, as discussed in the Introduction, this discipline is tacit and difficult for human experts to fully write out as a set of rules. Our key idea is to infer this discipline from existing exploit writeups. This design is based on the observation that exploit writeups naturally reflect how security experts apply the exploitability-analysis discipline in practice. Typically, a writeup includes the threat model, which specifies attack assumptions and attacker capabilities, the exploitability analysis explaining why the target field is considered exploitable or non-exploitable, and, when applicable, the attack procedure and corresponding PoCs. In this way, exploit writeups naturally preserve useful traces of the discipline. Therefore, LENS leverages existing exploit writeups to infer the exploitability-analysis discipline and subsequently uses it to guide Diameter exploitability analysis.

To this end, LENS leverages an LLM to infer the discipline and represent it as a prompt, denoted as p_{exp} . This

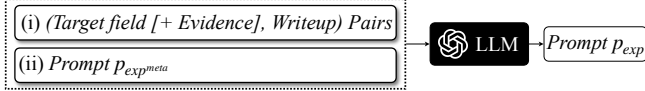


Figure 2: Inference of the exploitability-analysis prompt p_{exp} .

representation is natural because the exploitability-analysis discipline itself is essentially an instruction describing how exploitability analysis should be performed. Consequently, representing it as a prompt allows it to be directly provided to an LLM, enabling the inferred discipline to guide subsequent Diameter exploitability analysis, as shown in Step ② of Fig. 1. Fig. 2 illustrates the process used by LENS to infer p_{exp} . Specifically, we first construct a set of pairs from existing expert-written exploitability-analysis writeups. Each pair consists of (i) a target Diameter field together with its supporting protocol evidence and (ii) the corresponding expert-written writeup. Depending on the exploitability of the target field, the writeup may either document a successful exploitation case, including the corresponding attack procedure and PoC, or explain why exploitability cannot be established under the assumed threat model. These pairs define the desired inputs and outputs of exploitability analysis. By organizing expert-written analyses into such pairs, we can easily provide the LLM with examples of the desired analysis task. Once such pairs are constructed, we provide them to an LLM with a simple meta-prompt, denoted as $p_{expmeta}$ (shown in Table 1), which asks the LLM to infer a prompt that can derive the latter from the former and apply the same analysis process to new Diameter fields.

This design is inspired by recent studies showing that, given examples of task inputs and their corresponding outputs, LLMs can infer task instructions that reproduce the input-output mapping and generalize to unseen cases [7]. Following the same intuition, LENS leverages an LLM to infer p_{exp} from expert-written exploitability-analysis examples. Interestingly, our experiments suggest that the exploitability-analysis discipline can be inferred from surprisingly few examples. In particular, one exploitable and one non-exploitable example are already sufficient in our setting. Therefore, LENS uses a randomly selected exploitable example and a randomly selected non-exploitable example as seed examples for inferring p_{exp} . Detailed experimental results are presented in Section 4.4.

3.3. Evidence-Collection Guidance Inference

As discussed in the Introduction, protocol evidence is essential for Diameter exploitability analysis, yet remains difficult to collect in advance, even for security experts. In practice, experts typically follow a failure-driven process: they first perform analysis using currently available information and, when they find such information insufficient to support a conclusion, they revisit the relevant protocol specifications to identify and obtain the missing protocol evidence needed for further analysis. Recent studies have shown that LLMs can also learn from task failures and use failure feedback to infer how future inputs should be improved [8], [9], [15], [16], [17]. This capability naturally

TABLE 1: Template of p_{exp}^{meta} .

You are given several input-output examples for Diameter field analysis. Each input describes a target Diameter field together with its protocol evidence. Each output is an expert-written writeup, including an exploitability analysis report and a PoC (if the field is exploitable).

Your task is to infer a prompt that captures the exploitability-analysis discipline reflected by these examples and can guide analysis of unseen Diameter fields. Output only the inferred prompt.

Example format:

Input: {target field and protocol evidence}
Output: {exploitability-analysis writeup}

aligns with the failure-driven process used by experts to collect protocol evidence. Therefore, LENS leverages this capability to infer general evidence-collection guidance from exploitability-analysis failures.

Fig. 3 illustrates how LENS infers evidence-collection guidance. Specifically, when exploitability analysis performed using p_{exp} did not pass expert review, LENS provides an LLM with three inputs: (i) an analysis history, (ii) a failure feedback, and (iii) a meta-prompt (p_{evi}^{meta}), and asks the LLM to infer the evidence-collection guidance, represented as a prompt (p_{evi}). First, the analysis history records a previous LLM-based exploitability-analysis attempt: given a target Diameter field, the available protocol evidence (if any), and the prompt p_{exp} , the LLM generated a writeup consisting of an exploitability-analysis report and, when available, a corresponding PoC. This information provides the LLM with the context of how the incorrect writeup was generated. Second, the failure feedback includes two pieces of information: (1) the corresponding expert-written exploitability-analysis writeup and (2) an explicit indication that the LLM-generated writeup is incorrect. Together, they provide the LLM with the ground truth and a failure signal, supporting failure-driven self-reflection [15]. Finally, the meta-prompt (p_{evi}^{meta}) defines the objective of the LLM’s inference task (shown in Table 2). Rather than asking the LLM to identify the specific protocol evidence needed for the current target field, p_{evi}^{meta} instructs the LLM to infer a general evidence-collection guidance.

More specifically, it asks the LLM to infer a prompt (i.e., p_{evi}) that can collect the protocol evidence required for exploitability analysis, such that, when the collected evidence is combined with the target Diameter field recorded in the analysis history and p_{exp} , the resulting LLM-generated writeup can reproduce the corresponding ground-truth writeup.

Once inferred, p_{evi} is integrated into the first evidence-collection stage of the workflow shown in Fig. 1. For any target Diameter field, p_{evi} is used to collect the protocol evidence required for exploitability analysis in advance, which is then provided, together with the target field, to the subsequent exploitability-analysis stage guided by p_{exp} .

3.4. Iterative Co-Inference of the Two Prompts

As can be seen from the designs in Sections 3.2 and 3.3, the inference of p_{exp} and p_{evi} is inherently interdependent.

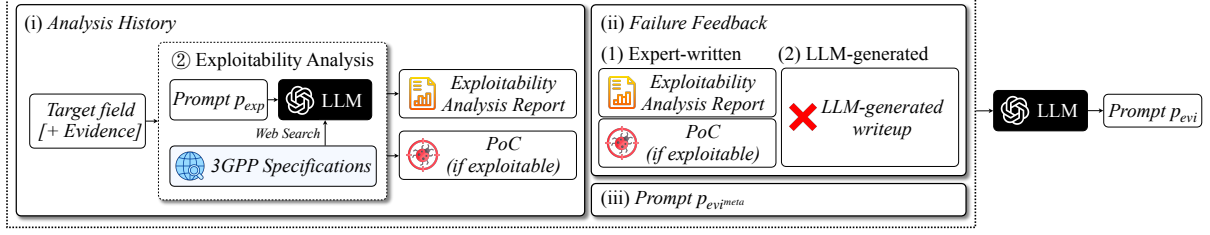


Figure 3: Inference of the evidence-collection prompt p_{evi} .

TABLE 2: Template of p_{evi}^{meta} .

I asked an LLM to analyze the exploitability of some 3GPP Diameter field paths. The LLM followed the exploitability-analysis prompt, p_{exp} , to analyze the target field paths. However, the LLM-generated exploitability analysis did not pass expert review. I believe the failures come from the LLM not knowing enough protocol context about each target field.

Failure case:

Analysis History:

{target field and protocol evidence}
 {exploitability-analysis prompt p_{exp} }
 {LLM-generated Writeup}

Failure Feedback:

{expert-written writeup}

Your task is to infer a general protocol evidence-collection prompt from these feedbacks. Given any Diameter field path as input, this prompt should instruct an LLM to search all the relevant 3GPP specifications and collect needed protocol context related to this field path for exploitability analysis and PoC construction, so that the generated context is sufficient to support reports reproducing the ground-truth reports. The prompt must be reusable on unseen Diameter field paths. Output only the inferred prompt.

On the one hand, inferring p_{exp} benefits from protocol evidence collected by p_{evi} . On the other hand, inferring p_{evi} relies on exploitability-analysis failures generated under p_{exp} . As a result, the two prompts cannot be inferred independently. To address this interdependence, our idea is to jointly refine the two prompts through an iterative process: LENS alternates between exploitability-analysis discipline inference and evidence-collection guidance inference, allowing failures generated under p_{exp} to support the inference of p_{evi} , and evidence collected by p_{evi} to support the inference of p_{exp} .

As the starting point of the iterative refinement process, LENS first infers an initial p_{exp} . Initially, only the target fields and their corresponding expert-written writeups are available. Although protocol evidence is unavailable, these examples nevertheless provide information from which an initial exploitability-analysis discipline can be inferred. Next, starting from the initial p_{exp} , LENS applies it to analyze the exploitable and non-exploitable examples used to infer it, and compares the generated writeups with the corresponding expert-written analyses. Whenever the generated writeups fail to reproduce the expert-written analyses, LENS performs a refinement round. In each refinement round, the resulting failures are used to infer p_{evi} , which collects protocol evidence for updating p_{exp} . The updated p_{exp} is then applied to the same examples again, producing a new

round of exploitability analysis. This process is repeated until the generated writeups successfully reproduce the corresponding expert-written analyses. Specifically, a writeup is considered successfully reproduced if (i) the generated exploitability conclusion is consistent with the expert-written one, (ii) the generated analysis is semantically equivalent to the expert-written analysis, as determined by expert review, and (iii) when the target field is exploitable, the generated PoC achieves the effect described in the corresponding writeup.

In practice, we find that the co-inference process converges quickly and typically requires only one to two rounds. After refinement, the resulting p_{exp} and p_{evi} together form the final exploitability-analysis discipline and evidence-collection guidance, which are then incorporated into the LENS workflow (Fig. 1) to guide exploitability analysis and PoC construction for previously unseen Diameter fields.

3.5. Security Impact Assessment

When a Diameter field is determined to be exploitable by LENS, the finding indicates a protocol-level security risk in Diameter. Building on these protocol-level findings, we further examine whether practical implementations are actually affected by them. To this end, we use the generated PoCs to perform security-impact assessment on implementations and investigate whether the predicted impacts indeed occur in practice.

Specifically, we perform the assessment in a controlled and isolated testing environment. Before the generated PoC can be applied, deployment-specific parameters, such as attacker identities, target network-element identities [18], and subscriber identities (e.g., IMSI or IMPI), are instantiated in the attack messages. The instantiated attack messages are then sent to the target network element following the LENS-generated attack procedure. Once the attack messages are sent, we manually monitor the state of the victim subscriber and the network responses returned during the attack, and assess whether the observed outcome is consistent with the impact predicted in the exploitability-analysis report. For attacks targeting subscriber services, we examine whether the victim subscriber exhibits the predicted behavior, such as losing network connectivity or becoming unable to access the intended services. For attacks that trigger information disclosure from the core network, we examine whether the returned Diameter messages contain the sensitive information predicted by the analysis. Detailed assessment results are presented in Section 5.2.

TABLE 3: Representative excerpts from p_{evi} .

Evidence Requirement

Your output must be a field-specific protocol evidence dossier that is sufficient for a later LLM to:

1. identify the normal sender and receiver
2. identify what the receiver does with the field
3. trace the concrete causal chain from this field to later protocol behavior, if any
4. explain how the receiving node is expected to process this field when the message is accepted
5. state whether this field can alter persistent, semi-persistent, or only transient state in the receiver

State and Authority Analysis

Determine what kind of authority this AVP has in protocol terms:

1. Does changing this field itself plausibly alter operational behavior?
2. Name the exact downstream procedures or messages that consume or reflect the field
3. If later legitimate signaling would overwrite the value, explain how and when

4. Evaluation

LENS is designed to infer exploitability-analysis discipline and evidence-collection guidance, and then use them to enable reliable LLM-based Diameter exploitability analysis. To evaluate whether LENS achieves this goal, we organize our evaluation around four questions: (1) Can LENS successfully infer exploitability-analysis discipline and evidence-collection guidance? (2) How effective is LENS? (3) What makes LENS effective? (4) What configurations are needed for LENS? We answer these questions in the following.

4.1. Understanding the Inferred Guidance and Discipline

The effectiveness of LENS relies on two inferred prompts, p_{evi} for protocol-evidence collection and p_{exp} for exploitability analysis. Before evaluating LENS, it is therefore important to understand whether LENS successfully infers exploitability-analysis discipline and evidence-collection guidance. To answer this question, we manually inspect a pair of final inferred prompts produced by LENS, focusing on two aspects: whether the inferred prompts generalize beyond the examples used for prompt inference and whether their contents indeed correspond to exploitability-analysis discipline and evidence-collection guidance.

Generality of the inferred prompts. Since both p_{evi} and p_{exp} are inferred from given examples, a natural concern is whether the inferred prompts merely capture patterns specific to those examples. We therefore examine the inferred prompts and find that neither p_{evi} nor p_{exp} contains any information tied to particular Diameter fields, messages, or interfaces appearing in the examples used for prompt inference. Instead, both prompts are expressed independently of any specific field. This suggests that the inferred prompts are general rather than example-specific.

The inferred evidence-collection guidance. We next examine the content of the inferred p_{evi} to understand whether

TABLE 4: Representative excerpts from p_{exp} .

Required Analysis Method

Base your reasoning on the supplied protocol evidence. Infer and explain:

1. Direction and receiver
 - Is the field in a request or answer?
2. Field semantics and placement
 - Exact grouped-AVP path and where the field sits.
3. Receiver processing
 - Is it authoritative input, just metadata, or only optional context?
4. State impact
 - What is the scope: per subscriber, per APN, per bearer, per serving-node context, temporary only, etc.?
5. Downstream/procedural consequences
 - What later procedures, decisions, or messages depend on this field?
6. Field-specific security relevance
 - Explain whether changing this field itself plausibly changes operation/security.
7. Overwrite/recovery
 - Is recovery immediate, eventual, or unlikely?
8. PoC feasibility
 - If exploitable, determine the minimum coherent message structure needed to exercise the field.

it indeed provides guidance on what protocol evidence should be collected and how such evidence can be obtained. Our analysis suggests that it does. Table 3 illustrates two representative excerpts from p_{evi} . The first excerpt defines a high-level scope of protocol information that should be collected by the LLM, including not only the semantics of the target field, but also sender and receiver roles, subscriber or network state updates, authority relationships, and downstream telecom effects. The second excerpt guides the LLM to analyze the protocol authority of the target field and its potential influence on subscriber or network state, such as whether it acts as an authoritative control point and what state entries may be modified if the field is manipulated. Beyond these examples, the prompt p_{evi} further provides a rich set of specific strategies for evidence collection, such as identifying downstream protocol effects, tracing state changes caused by the target field, and locating the protocol information required for PoC construction.

The inferred exploitability-analysis discipline. Unlike p_{evi} , which guides the collection of protocol evidence, p_{exp} is intended to guide how the collected evidence should be used for exploitability analysis. We therefore examine the content of the inferred p_{exp} and find that it indeed encodes exploitability-analysis discipline. Table 4 illustrates a representative excerpt from p_{exp} . The excerpt does not directly ask the LLM to determine whether a field is Exploitable or Non-Exploitable. Instead, it requires the LLM to first infer and use a series of protocol facts before reaching a conclusion. These facts include message direction, AVP semantics, receiver processing, state and authority relationships, downstream consequences, and PoC feasibility. These considerations closely align with those typically examined by security experts during exploitability analysis, consistent with the intended role of p_{exp} in our design. Beyond the excerpt shown in Table 4, the full prompt further expands

TABLE 5: End-to-End effectiveness of LENS.

Model	Recall (%)	Precision (%)	Accuracy (%)	Fields correct in $\geq 4/5$ runs
GPT	96.00 $\pm$ 4.18	88.94 $\pm$ 2.12	92.00 $\pm$ 2.09	37/40
GLM	94.00 $\pm$ 4.18	78.73 $\pm$ 6.28	84.00 $\pm$ 5.18	31/40
Claude	98.00 $\pm$ 2.74	86.03 $\pm$ 3.31	91.00 $\pm$ 2.85	35/40
Gemini	96.00 $\pm$ 4.18	84.50 $\pm$ 5.17	89.00 $\pm$ 3.79	35/40

these considerations into detailed decision criteria and PoC-generation requirements; the complete prompt can be found in our artifact [19].

Overall, these observations suggest that LENS successfully infers generalizable evidence-collection guidance and exploitability-analysis discipline.

4.2. End-to-End Effectiveness

LENS is designed to perform reliable field-level Diameter exploitability analysis. We therefore evaluate whether it can achieve this goal in practice. To answer this question, we manually construct an evaluation dataset consisting of 40 Diameter fields covering both exploitable and non-exploitable cases across two representative Diameter interfaces considered in this work, S6a and Cx. For each interface, we randomly sample Diameter fields and manually analyze them until obtaining a balanced set consisting of 10 exploitable and 10 non-exploitable fields, resulting in 20 fields from S6a and 20 fields from Cx. Constructing such an evaluation dataset requires expert analysis of the Diameter specifications, often involving information distributed across multiple documents. For each field, we manually analyze the relevant specifications, determine whether it is exploitable under our threat model, and produce the corresponding exploitability analysis report and protocol-level PoC when applicable. Here, none of the examples used during prompt inference are included in our evaluation dataset.

On this dataset, we evaluate LENS using four underlying LLMs: GPT-5.4, GLM-5.2, Claude Opus 4.6, and Gemini 3.1 Pro. For each LLM, we independently execute the complete LENS pipeline five times. Each run starts from the same fixed seed examples but re-infers and refines both p_{exp} and p_{evi} from scratch, followed by evidence collection and exploitability analysis for all 40 evaluation fields. A result produced by LENS is considered correct only if (i) the exploitability conclusion is correct, (ii) the LENS-generated analysis is semantically equivalent to the reference analysis, and (iii) for exploitable fields, the LENS-generated attack procedure and attack messages are consistent with the reference PoC. This criterion is identical to that used in Section 3.4 for determining whether an LLM-generated exploitability-analysis writeup successfully reproduces the corresponding expert-written writeup.

Effectiveness of LENS. Table 5 presents the effectiveness of LENS, reporting recall, precision, and accuracy as mean $\pm$ standard deviation across five runs. Across the four LLMs, LENS achieves mean recall of 94.00% to 98.00%, mean precision of 78.73% to 88.94%, and mean accuracy of 84.00% to 92.00%. In particular, the consistently high recall shows that LENS correctly identifies nearly all exploitable fields and successfully produces the corresponding exploitability-analysis writeups. Table 14 in the Appendix additionally

TABLE 6: Runtime and cost of LENS.

Model	Runtime (min/field)	Cost (USD/field)
GPT	1.81 $\pm$ 0.31	0.230 $\pm$ 0.014
GLM	2.15 $\pm$ 0.10	0.148 $\pm$ 0.002
Claude	1.92 $\pm$ 0.12	0.298 $\pm$ 0.045
Gemini	1.77 $\pm$ 0.10	0.234 $\pm$ 0.006

breaks down the results by Diameter interface, reporting performance separately for S6a and Cx.

Beyond these aggregate metrics, we further examine whether the same fields are correctly analyzed across repeated runs. As shown in Table 5, GPT correctly analyzes 37/40 fields in at least four of five runs; Claude and Gemini each correctly analyze 35/40, while GLM correctly analyzes 31/40. These results show that, for every LLM, LENS repeatedly produces correct analyses for most benchmark fields across independent runs. A more detailed breakdown of this run-to-run consistency is provided in Table 15.

To understand the errors made by LENS, we further manually inspect every field that is misclassified in any run of any LLM. Across 800 analyses (40 fields $\times$ 4 LLMs $\times$ 5 runs), LENS makes 88 misclassifications across 16 fields: 72 false positives and 16 false negatives. We find that the 72 false positives fall into three recurring categories: attributing a message-level security effect to the target field, combining separate protocol behaviors into an invalid exploit chain, and overlooking protocol constraints because the collected evidence is incomplete. By contrast, all 16 false negatives share the same cause: LENS assumes additional receiver-side authorization checks that are not required by the protocol specifications, causing feasible exploits to be rejected.

Efficiency and cost of LENS. Since p_{evi} and p_{exp} are constructed once and then reused across target fields, we evaluate the runtime and monetary cost of analyzing each target Diameter field. Table 6 reports both as mean $\pm$ standard deviation over the same five runs used in the effectiveness evaluation for each LLM. Across the four LLMs, analyzing one field requires 1.77 to 2.15 minutes on average and incurs an average monetary cost of \$0.148 to \$0.298. These results indicate that LENS can analyze Diameter fields with low per-field runtime and monetary cost across different LLMs.

4.3. Understanding LENS Effectiveness

To understand why LENS achieves high exploitability-analysis performance, we further evaluate the effectiveness of its key design choices. Using the same evaluation dataset and evaluation criterion as in Section 4.2, we investigate two questions: (1) whether reliable exploitability analysis requires both exploitability-analysis discipline and protocol evidence, and (2) whether the proposed guidance-inference design is necessary and effective compared with simpler alternatives. These controlled studies use GPT-5.4 and the corresponding initial and refined prompts obtained from its first run in Section 4.2.

Effectiveness of discipline and evidence. To answer the first question, we evaluate three configurations of increasing capability: (1) Simple Prompt, which performs ex-

TABLE 7: Effectiveness of discipline and evidence in LENS. *Discipline: exploitability-analysis discipline; Evidence: protocol evidence.*

Configuration	Discipline Evidence		Recall	Precision	Accuracy
Simple Prompt	✗	✗	30.00%	37.50%	40.00%
Initial p_{exp}	✓	✗	40.00%	80.00%	65.00%
Initial p_{exp} + Initial p_{evi}	✓	✓	80.00%	84.21%	82.50%

exploitability analysis without any guidance; (2) Initial p_{exp} , which performs exploitability analysis using the inferred exploitability-analysis discipline; and (3) Initial p_{exp} + Initial p_{evi} , which further provides protocol evidence collected using the inferred evidence-collection guidance. Here, we intentionally use the initial inferred prompts before refinement, as our goal is to understand the contributions of exploitability-analysis discipline and protocol evidence themselves.

Table 7 presents the results. The Simple Prompt configuration achieves only 30.00% recall, 37.50% precision, and 40.00% accuracy. Providing exploitability-analysis discipline (i.e., Initial p_{exp}) substantially improves performance, increasing accuracy from 40.00% to 65.00% and more than doubling precision from 37.50% to 80.00%, while recall improves modestly. These results suggest that exploitability-analysis discipline plays an important role in reliable LLM-based Diameter exploitability analysis, particularly through improving precision. Adding protocol evidence (i.e., Initial p_{evi}) further improves performance. Compared with using exploitability-analysis discipline alone, providing protocol evidence increases accuracy from 65.00% to 82.50% and doubles recall from 40.00% to 80.00%, while still achieving high precision. These results suggest that protocol evidence also plays an important role in reliable LLM-based Diameter exploitability analysis, particularly in improving recall.

Overall, the results suggest that both exploitability-analysis discipline and protocol evidence are necessary for reliable LLM-based Diameter exploitability analysis. They play complementary roles, with the former primarily improving precision and the latter primarily improving recall.

Effectiveness of guidance-inference design. Having established the importance of exploitability-analysis discipline and protocol evidence, we next evaluate whether the corresponding design choices in LENS are more effective than simpler alternatives. Specifically, we evaluate three components of our design: exploitability-analysis discipline inference (Section 3.2), evidence-collection guidance inference (Section 3.3), and guidance refinement (Section 3.4).

• **Exploitability-analysis discipline inference.** As discussed in Section 3.2, existing exploit writeups reflect the tacit exploitability-analysis discipline used by security experts. Therefore, to make such discipline available to LLMs for reliable exploitability analysis, LENS infers the discipline from exploit writeups using the procedure illustrated in Figure 2. An immediate question is whether such inference is necessary, or whether directly providing the same exploit writeups as few-shot demonstrations would be sufficient. To evaluate the effectiveness of discipline inference, we compare it against a few-shot baseline that uses the same exploitable and non-exploitable examples used for discipline

TABLE 8: Effectiveness of the guidance-inference design.

Component	Configuration	Recall	Precision	Accuracy
p_{exp} Inference	Few-shot Examples	35.00%	77.78%	62.50%
	Inferred p_{exp}	45.00%	100.00%	72.50%
p_{evi} Inference	Keyword Retrieval	55.00%	73.33%	67.50%
	Field-Relevant Retrieval	40.00%	88.89%	67.50%
	Exploitability-Relevant Retrieval	50.00%	83.33%	70.00%
	Inferred p_{evi}	80.00%	84.21%	82.50%
Joint Refinement	Initial p_{exp} + Initial p_{evi}	80.00%	84.21%	82.50%
	Refined p_{exp} + Refined p_{evi}	100.00%	90.91%	95.00%

inference. Table 8 presents the results. The few-shot baseline achieves 77.78% precision and 62.50% accuracy, suggesting that directly providing exploit writeups allows the LLM to partially leverage the exploitability-analysis discipline embedded in them. However, the inferred exploitability-analysis discipline achieves higher precision and accuracy, improving them to 100.00% and 72.50%, respectively, while providing a modest improvement in recall. These results suggest that inferring exploitability-analysis discipline is more effective than directly using the same examples as demonstrations, supporting the design choice of discipline inference in LENS.

• **Evidence-collection guidance inference.** As discussed in Section 3.3, the protocol evidence required for exploitability analysis cannot be identified in advance. To address this challenge, LENS learns evidence-collection guidance from exploitability-analysis failures using the procedure illustrated in Figure 3. A natural question is whether such guidance inference is necessary, or whether the required protocol evidence can be collected using simpler retrieval-based approaches. To evaluate the effectiveness of evidence-collection guidance inference, we compare it against three retrieval-based baselines following the standard RAG paradigm [20]: (1) Keyword Retrieval, which collects all specification sections containing the target field through keyword matching; (2) Field-Relevant Retrieval, which prompts the LLM to collect information generally related to the target field; and (3) Exploitability-Relevant Retrieval, which prompts the LLM to collect information specifically relevant to exploitability analysis of the target field.

Table 8 presents the results. Using the protocol evidence collected by the retrieval-based baselines, exploitability analysis achieves recall ranging from 40.00% to 55.00% and accuracy ranging from 67.50% to 70.00%. In contrast, using the protocol evidence collected by the inferred p_{evi} , exploitability analysis achieves 80.00% recall and 82.50% accuracy, substantially outperforming all retrieval-based baselines while maintaining comparable precision. These results suggest that how protocol evidence is collected has a substantial impact on exploitability-analysis performance. In particular, learning evidence-collection guidance from exploitability-analysis failures is more effective than retrieval-based evidence collection, supporting the design choice of evidence-collection guidance inference in LENS.

• **Refinement of p_{exp} and p_{evi} .** As discussed in Section 3.4, the inference of p_{exp} and p_{evi} depends on each other, as

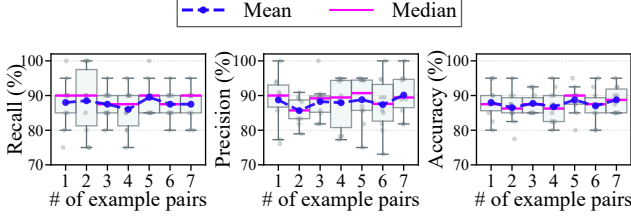


Figure 4: Effect of the number of example pairs on prompt inference.

exploitability-analysis discipline affects evidence collection, while collected evidence in turn affects discipline inference. Therefore, the initially inferred prompts are further refined through iterative refinement. To evaluate the effectiveness of this design, we compare the initially inferred prompts against the final refined prompts obtained after refinement. Table 8 presents the results. Compared with initial p_{exp} + initial p_{evi} , refinement substantially improves performance across all evaluation metrics. Most notably, refinement increases recall from 80.00% to 100.00%, meaning that all exploitable fields in the evaluation dataset are successfully identified. Meanwhile, precision and accuracy are further improved, reaching 90.91% (from 84.21%) and 95.00% (from 82.50%), respectively. These results demonstrate that iterative refinement further enhances the effectiveness of the inferred guidance, enabling highly reliable LLM-based Diameter exploitability analysis.

4.4. Configuration Study

Having established the effectiveness of LENS and its key design choices, we next study the configurations of LENS. In particular, LENS involves several configurable choices, including the number of examples used for prompt inference, the number of co-inference refinement rounds, and the information used for evidence-collection guidance inference. Studying these choices helps identify the configurations needed for reliable exploitability analysis. We therefore investigate two questions: (1) how many examples are needed for prompt inference, and (2) what information is needed for evidence-collection guidance inference. We use GPT-5.4 throughout this section.

Number of examples. As discussed in Section 3.2, LENS infers its exploitability-analysis prompt from examples constructed from expert-written exploit writeups. We first study how many such examples are needed for prompt inference. To answer this question, we construct a prompt-inference dataset consisting of eight previously reported exploitable Diameter cases [21], [22], [23], [24] and eight manually constructed non-exploitable cases. This dataset is used only for prompt inference and is separate from the evaluation dataset used in Section 4.2. On this dataset, we evaluate how the number of examples used for prompt inference affects the resulting exploitability-analysis performance. Specifically, we start with one exploitable case and one non-exploitable case, and gradually increase the number to seven exploitable cases and seven non-exploitable cases. For each setting, we randomly select ten different combinations of exploitable and

TABLE 9: Effect of information used for p_{evi} inference.

LLM-Generated Writeup	Expert-Written Writeup	Analysis History	Recall	Precision	Accuracy
✓	✗	✗	55.00%	84.62%	72.50%
✓	✗	✗	70.00%	87.50%	80.00%
✓	✓	✓	80.00%	84.21%	82.50%

non-exploitable cases from the prompt-inference dataset, infer the corresponding prompts, and evaluate them on the evaluation dataset used in Section 4.2. Figure 4 presents the results.

Across all settings, the inferred prompts achieve comparable recall, precision, and accuracy. Although using more examples occasionally leads to slight improvements in these metrics, the gains are marginal. Overall, we do not observe a consistent trend that increasing the number of examples improves exploitability-analysis performance. Taken together, these observations suggest that reliable prompt inference can be achieved with only a small number of examples. In particular, we do not observe clear benefits from using more than one exploitable case and one non-exploitable case. LENS therefore adopts this configuration throughout the paper.

Information for p_{evi} inference. As discussed in Section 3.3, LENS infers p_{evi} using three types of information obtained from a failed exploitability analysis: (1) the LLM-generated writeup together with a failure signal indicating that the analysis did not pass expert review, (2) the corresponding expert-written writeup as ground truth, and (3) the analysis history describing how the incorrect writeup was produced. Next, we study whether each type of information contributes to p_{evi} inference. To this end, we fix the initial p_{exp} obtained from the first GPT-5.4 run in Section 4.2 and progressively provide these information sources for p_{evi} inference. For each setting, we infer the resulting p_{evi} and evaluate it on the evaluation dataset used in Section 4.2. As shown in Table 9, providing additional information consistently improves performance. Starting from the LLM-generated writeup and failure signal alone, adding the expert-written writeup substantially improves all three metrics, increasing recall from 55.0% to 70.0%, precision from 84.6% to 87.5%, and accuracy from 72.5% to 80.0%. Further providing the analysis history continues to improve performance, increasing recall from 70.0% to 80.0% and accuracy from 80.0% to 82.5%, while causing only a small decrease in precision. Taken together, these results justify the use of all three types of information for p_{evi} inference.

5. Findings

Section 4 demonstrates the effectiveness of LENS for Diameter exploitability analysis. We now apply LENS to the Diameter protocol at scale to understand its security landscape at both the protocol and implementation levels. Using GPT-5.4 with the p_{evi} and p_{exp} from the first run in Section 4.2, we first investigate which Diameter fields are exploitable at the protocol level under our threat model, and then examine how prevalent these protocol-level weaknesses are in practical implementations. The following subsections

TABLE 10: Protocol-level exploitability findings.

Interface	Total Fields	LENS-identified	Validated	New
S6a	600	176 (29.33%)	160 (26.67%)	152
Cx	166	47 (28.31%)	44 (26.51%)	44
Overall	766	223 (29.11%)	204 (26.63%)	196

present protocol-level findings, implementation-level findings, and representative attacks revealed by our analysis.

5.1. Protocol-Level Findings

To understand the security landscape of Diameter, we use LENS to analyze the S6a and Cx interfaces, which are responsible for LTE subscriber management and authentication, and IMS service control (e.g., voice-call services), respectively [10], [12]. This analysis covers 766 fields, including 600 fields in S6a and 166 fields in Cx.

As shown in Table 10, LENS initially identifies 223 fields as exploitable. To verify whether these fields are indeed exploitable at the protocol level, we manually audit all 223 fields. For each field, we check whether the collected evidence is sufficient and verifiable and whether it supports the claimed field-specific exploitability. This audit confirms 204 fields. The other 19 do not pass the audit for reasons consistent with the failure modes observed in Section 4.2. Accordingly, using LENS, we identify 204 validated protocol-level exploitability findings. This means that over one quarter of the 766 analyzed Diameter fields (26.63%) are exploitable under our threat model, revealing widespread field-level exploitability once Diameter network elements become reachable. More importantly, 196 of these exploitable fields (96.08%) have not been reported in prior academic literature or public attack reports.

To further understand the security consequences associated with these exploitable fields, we analyze their corresponding protocol-level PoCs. In total, LENS generates 222 protocol-level PoCs for the 204 validated exploitable fields. The number of generated PoCs exceeds the number of exploitable fields because the same field may lead to different behaviors when assigned different values, resulting in multiple distinct security consequences. After analyzing the generated PoCs, we find that they lead to diverse security consequences. Table 11 summarizes our categorization of these consequences. The results reveal a clear concentration around service availability: the most common consequences are service disruption and service degradation, accounting for 85 (38.29%) and 76 (34.23%) PoCs, respectively. Service disruption can completely disable subscriber services, such as voice calls, SMS, or Internet access, while service degradation can significantly reduce service quality, for example by forcing subscriber network traffic to extremely low data rates (e.g., 1 KB/s). These two categories account for nearly three quarters (72.52%) of all generated PoCs, indicating that most identified threats ultimately affect the availability of subscriber services. Beyond impacts on service availability, we also observe additional security and privacy consequences that directly affect subscribers. In particular, 32 PoCs (14.41%) trigger information leakage, exposing sensitive subscriber information such as authentication vectors

TABLE 11: Security consequences of protocol-level PoCs.

CID	Consequence Category	PoCs	Percentage
C1	Service Disruption	85	38.29%
C2	Service Degradation	76	34.23%
C3	Information Leakage	32	14.41%
C4	Battery Depletion	15	6.76%
C5	Subscriber Tracking	14	6.31%
Total		222	100.00%

TABLE 12: Implementation-level assessment results.

Impl.: implementation; *Intf.*: interface; *EF*: exploitable fields; *T*: type (*O*: open-source; *C*: commercial); *Vulns.*: vulnerabilities.

Impl.	T	Intf.	Supported EF	Confirmed EF(%)	Associated PoCs	Confirmed Vulns.(%)
Open5GS	O	S6a	25	4 (16.00%)	28	7 (25.00%)
Kamailio	O	Cx	9	9 (100.00%)	15	10 (66.67%)
Commercial A	C	S6a	40	35 (87.50%)	46	40 (86.96%)
Commercial A	C	Cx	16	16 (100.00%)	24	23 (95.83%)
Commercial B	C	Cx	16	15 (93.75%)	18	15 (83.33%)
Overall			56	51 (91.07%)	71	64 (90.14%)

and subscriber-profile data (e.g., phone numbers and service configurations). Another 15 PoCs (6.76%) cause accelerated battery depletion by forcing victim devices to repeatedly perform network procedures and consume excessive power. In addition, 14 PoCs (6.31%) enable precise cell-level subscriber tracking or monitoring of subscriber online status. These findings show that, although the exploitable fields reside in core-network signaling protocols, their impacts ultimately affect subscribers, threatening not only service availability, but also subscriber privacy and device usability.

Field-level and message-level views. Since LENS analyzes exploitability at the granularity of individual Diameter fields, the findings above are reported at the field level. To provide a complementary view of these findings, we further characterize the 204 validated fields by the Diameter message, receiver, and receiver-side operation involved. In total, we identify 49 distinct scenarios. For example, 18 exploitable fields associated with the IDR message can each be manipulated by an attacker impersonating the HSS to update the UE’s APN/PDN connectivity configuration at the MME, leading to service disruption or service degradation. Appendix Table 16 presents the complete results.

5.2. Implementation-Level Findings

To examine whether the protocol-level findings identified above also hold in practical implementations, we conduct implementation-level assessment in four testing environments, including two open-source core-network implementations (Open5GS [25] and Kamailio [26]) and two anonymized commercial core-network implementations, denoted as Commercial A and Commercial B. Open5GS supports the S6a interface, Kamailio supports the Cx interface, Commercial A supports both S6a and Cx, and Commercial B supports Cx. All assessments are conducted in isolated environments separated from operational networks.

Table 12 summarizes the results. Among the 204 protocol-level exploitable fields identified in Section 5.1, only 56 are supported by at least one evaluated imple-

mentation. The difference arises because many Diameter fields are optional, and different implementations support different subsets of protocol functionalities. Among these 56 supported fields, we find that 51 (91.07%) are confirmed to be exploitable in at least one implementation, while 64 (90.14%) of their corresponding 71 protocol-level PoCs successfully trigger the predicted security impacts. The high field-confirmation rate (91.07%) and PoC-success rate (90.14%) indicate that practical implementations are highly likely to be affected if the corresponding protocol functionality is implemented.

To understand why some supported protocol-level weaknesses do not produce the predicted impacts, we further analyze the unsuccessful cases. Since the source code of the commercial implementations is unavailable, we focus our analysis on the open-source implementations. Our analysis reveals that the unsuccessful cases stem from two implementation-specific decisions. In Open5GS, all unsuccessful cases are caused by the same implementation-specific behavior. When a UE re-attaches to the network, Open5GS always retrieves fresh subscriber data from the HSS and overwrites the subscriber state previously manipulated by the PoC in the MME, thereby eliminating the attack effects. This behavior is not required by the 3GPP specifications [10], but is instead an implementation-specific design choice made by Open5GS. In Kamailio, all unsuccessful cases arise because the implementation supports the target fields but does not implement the functionalities associated with the manipulated field values. As a result, setting these fields to the manipulated values cannot trigger the expected protocol behaviors or security impacts.

We further analyze the concrete impacts caused by the 64 PoCs observed in our evaluated implementations. We find that these impacts cover all security-consequence categories identified in Section 5.1. For example, the observed impacts include complete LTE service loss, exposure of subscriber authentication vectors, and precise cell-level subscriber tracking. The detailed impacts are summarized in Table 13, while Appendix Table 17 provides a complete list of the corresponding fields, interfaces, impact categories, and affected implementations for all 64 validated PoCs.

Overall, we identify 95 previously unknown implementation-specific vulnerabilities, including 17 in the two open-source implementations and 78 in the two commercial implementations. This number exceeds the 64 PoCs whose predicted impacts are successfully observed in our evaluated implementations, as some PoCs affect multiple implementations. We responsibly disclosed all identified vulnerabilities to the affected vendors and maintainers. Notably, both commercial vendors confirmed all reported vulnerabilities. At the time of writing, 5 CVE identifiers and 7 CNVD identifiers have been assigned to the reported Open5GS vulnerabilities, while the remaining cases are under review.

5.3. Representative Attacks

The protocol-level PoCs identified by LENS already reveal powerful attack capabilities against cellular core net-

TABLE 13: Security impacts of confirmed vulnerabilities.

CID	Impact	Vulnerabilities
C1	Complete LTE service loss	25
	All voice and SMS services unavailable	8
	Incoming voice calls and SMS unavailable	9
	<i>Total</i>	42
C2	Data rate reduced to extremely low levels	6
	Only IPv6 services remain accessible	2
	<i>Total</i>	8
C3	Exposure of subscriber profile information	2
	Exposure of subscriber authentication vectors	2
	Exposure of network-element capabilities	4
	Exposure of internal network configuration	2
	<i>Total</i>	10
C4	Accelerated battery drain	1
	<i>Total</i>	1
C5	Precise cell-level location tracking	1
	Monitoring subscriber online status	2
	<i>Total</i>	3

works. To further illustrate their practical implications, we present three representative attacks constructed in our study, all of which are previously unreported to the best of our knowledge and have been successfully demonstrated in our testbed.

Persistent rogue-network attachment. This attack enables an attacker to transparently take over a victim UE’s cellular connectivity, including data, voice, and messaging services, by constructing a rogue EPS/IMS network. Normally, such an attack would be prevented because a rogue network cannot complete UE-network mutual authentication without valid authentication material. However, by combining multiple information-leakage PoCs (PID-4, PID-5, PID-51, and PID-54 in Appendix Table 17), the attacker can obtain both the required authentication material and subscriber profiles from the HSS, enabling the construction of a rogue EPS/IMS network. After constructing the rogue network, the attacker can leverage the service-disruption PoC (PID-2) to send a crafted *Cancel-Location-Request (CLR)*, forcing the victim UE to detach from the legitimate network. When the UE subsequently performs network reselection, the attacker can attract it to the attacker-controlled network through a rogue eNB broadcasting a stronger signal. The attacker-controlled network can then use the stolen EPS-AKA and IMS-AKA authentication vectors to complete EPS attachment and IMS registration, and use the obtained subscriber profiles to provide cellular and IMS services that are indistinguishable from those of the legitimate network.

This attack highlights the severity of the information exposed by the identified Diameter vulnerabilities. The exposed authentication vectors and subscriber profiles are not merely pieces of subscriber information; together, they provide all critical materials required to construct a rogue EPS/IMS network. As a result, an attacker can impersonate a legitimate operator and gain full control over the victim’s cellular connectivity, including data, voice, and messaging services.

Persistent LTE service loss. This attack enables an attacker to cause persistent LTE service loss for a victim UE by

modifying APN-related subscriber configuration stored in the MME. These configuration parameters are required for the MME to provide cellular data service to the UE, and invalid values can prevent the service from being successfully established. Using Diameter vulnerabilities that can modify APN-related configuration (e.g., PID-11 to PID-22), an attacker can replace legitimate values with invalid ones. Additionally, to immediately trigger the attack, the attacker can further leverage a service-disruption PoC (e.g., PID-2) to force the victim UE to perform a new attach procedure. During the subsequent attach procedure, the MME will use the modified configuration. Because the modified configuration is invalid, the MME fails to establish service for the UE, causing the victim UE to lose LTE service [27].

The impact of this attack can be particularly severe. Once the attack succeeds, the victim UE may remain without LTE service throughout the service area of the affected MME. Repeated device reboots or enabling and disabling airplane mode do not restore connectivity, because the serving MME continues to use the modified subscriber configuration. In our testbed, the victim remained disconnected until it moved outside the service area of the affected MME and attached through another MME.

Accelerated battery depletion. This attack enables an attacker to significantly accelerate battery depletion of a victim UE by modifying the periodic TAU timer delivered by the MME [28]. The timer determines how frequently the UE performs periodic TAU procedures to maintain its network registration. Using the timer-modification vulnerability (PID-41), an attacker can set the timer to only a few seconds. To trigger the MME to deliver the modified timer to the UE, the attacker can further leverage a service-disruption PoC (e.g., PID-2) to force the victim UE to perform a new attach procedure. This is because the modified timer is only delivered during network attachment procedures. As a result, after re-attaching to the network, the UE will repeatedly perform network signaling far more frequently than intended, significantly increasing battery consumption.

The impact of this attack can be particularly severe for battery-powered IoT devices, which often rely on long idle intervals to achieve extended battery lifetime. In our testbed, we set the timer to 2 seconds and evaluated the attack on two battery-powered IoT devices: a low-power edge gateway and a low-power data collector. The impact was substantial. For the former device, which is advertised with a three-year battery lifetime, the attack depleted the battery within only 83 hours. For the latter device, which is advertised with a one-month battery lifetime, the battery was exhausted within 13 hours. These results demonstrate that a single Diameter attack can drastically shorten the operational lifetime of battery-powered cellular devices from months or years to only a few days or even hours.

6. Generalizability Beyond Diameter

Although LENS is developed for Diameter exploitability analysis, its underlying methodology is not tied to Diameter. The core capability provided by LENS is the inference

of protocol-specific exploitability-analysis guidance from a small number of examples. We therefore ask whether this capability can generalize beyond Diameter and support exploitability analysis for protocols in other domains.

To answer this question, we apply LENS to 16 additional widely used protocols spanning diverse domains, such as VoIP communication, Internet routing, and IoT messaging. Importantly, no component of LENS is modified. Using GPT-5.4 and the same configuration used for Diameter analysis (Section 4.4), we simply replace the Diameter examples used for prompt inference with one exploitable example and one non-exploitable example specific to the target protocol, and then use the inferred guidance to analyze the target protocol. In total, the evaluated protocols comprise 857 protocol fields. Table 18 summarizes the results. Across the 857 protocol fields, LENS generated 279 protocol-level PoCs, including 129 previously reported vulnerabilities and 150 previously unreported ones. To assess whether these findings affect real implementations, we further evaluated the 150 previously unreported ones on representative open-source implementations. We confirmed that 118 of them can successfully trigger their predicted security impacts, achieving attacks such as unauthorized message injection, session hijacking, response manipulation, denial of service, and information leakage. Moreover, we have responsibly disclosed these vulnerabilities to the affected open-source projects. To date, 8 vulnerabilities affecting 7 vendors have been confirmed. The disclosures have resulted in 1 CVE assignment and 7 CNVD identifiers, while many additional reports remain under review.

Overall, these results suggest that LENS does not rely on protocol-specific designs tailored to Diameter. Without modifying its methodology, LENS remains effective across a diverse set of protocols, demonstrating the strong transferability of the methodology underlying LENS.

7. Discussion

LENS and protocol fuzzing. One may ask how LENS compares with protocol fuzzing. To examine this, we construct a Diameter fuzzing baseline on top of DiaFuzzer [29], an open-source Diameter message fuzzer, and compare it with LENS on the same 64 implementation-confirmed PoCs from Section 5.2. To focus the comparison on methodological differences rather than DiaFuzzer-specific limitations, we strengthen this baseline to systematically mutate each target field across all functional values explicitly defined in the Diameter specifications and add four security oracles following prior LTE fuzzing and dynamic-testing work [30], [31], [32] — automated checks for LTE connectivity loss, data-service failure, voice-service failure, and information leakage. Table 19 in the appendix shows the results. With these extensions, the fuzzing baseline generates the same field-value manipulations used in all 64 PoCs produced by LENS, but automatically detects the security effects of only 26 (40.63%). For the remaining 38 PoCs, detecting their security effects requires additional test logic: for 29, the security effect becomes observable only after a specific

subsequent action, such as UE reattachment, roaming, location change, TAU, or S-CSCF restart, while the other 9 require custom detection procedures tailored to their specific security effects (e.g., bearer QoS degradation, reduced data rate, battery drain, or IMS service failure). Thus, the fuzzing baseline fails to identify these 38 PoCs as successful attacks. These results suggest that a stateful fuzzer could in principle identify these attacks if the necessary subsequent actions and security checks were known and encoded in advance. Determining them, however, requires reasoning about how each field affects downstream protocol behavior. This is precisely the field-level exploitability problem that LENS is designed to address: by reasoning over field semantics and downstream behavior, LENS identifies exploitable field-value manipulations, constructs the corresponding attack procedures, and predicts their security effects.

From case-based discovery to systematic discovery. A longstanding challenge in security analysis is that many security discoveries rely on expert knowledge accumulated through experience, yet often difficult to explicitly articulate and transfer, making vulnerability discovery largely a manual and case-by-case process. Our results suggest a potential opportunity to change this dynamic. By inferring reusable security-analysis guidance from a small number of expert-discovered cases, LENS provides evidence that such knowledge can be systematically captured, externalized, and propagated. More broadly, this raises the possibility that security discovery may gradually evolve from a predominantly case-based activity toward a more systematic process.

The challenge of practical mitigation. Given that the vulnerabilities discovered by LENS rely on publicly reachable Diameter interfaces and disabled TLS protection, a natural question is whether the risks can be eliminated by simply addressing these two conditions. However, our discussions with operators and vendors suggest that publicly reachable core-network elements and disabled TLS protection will continue to exist in operational environments due to complex operational considerations, such as deployment, maintenance, interoperability, and performance requirements. As a result, new risks continue to be discovered and threaten core-network operations, while the insecure deployment conditions are unlikely to disappear anytime soon, creating a persistent operational challenge for core networks.

Limitation. One limitation of this work is the size of the manually labeled evaluation dataset introduced in Section 4.2. Constructing ground-truth labels for Diameter exploitability analysis requires expert-driven protocol analysis and, in many cases, PoC construction, making large-scale labeling expensive and time-consuming. As a result, our evaluation is conducted on a dataset of 40 protocol fields. While this dataset covers both exploitable and non-exploitable fields across the S6a and Cx interfaces and the effectiveness of LENS is further supported by large-scale protocol analysis and implementation-level validation, a larger ground-truth dataset would further strengthen the evaluation.

8. Related Work

Security analysis of cellular networks. Prior work has developed automated techniques for analyzing cellular-network security, mainly through testing-based analysis [31], [33], [34], [35], formal verification [36], [37], [38], [39], and fuzzing [30], [40], [41], [42]. Testing-based approaches typically execute cellular protocol procedures or implementations and analyze whether their behaviors follow expected protocol specifications. Formal methods usually construct models of protocol procedures and verify predefined security properties. Fuzzing-based approaches often mutate signaling messages [41], protocol fields [30], or protocol states [40] to expose abnormal implementation behavior. Collectively, these works primarily study whether cellular protocol procedures satisfy expected security properties, whether implementations comply with protocol requirements, or whether malformed signaling messages can expose implementation bugs. Our work studies a different problem: automatically determining whether protocol-compliant functionality can be leveraged by attackers to cause security consequences.

LLM-assisted security analysis. Recent work has applied LLMs to a wide range of security tasks, such as penetration testing [43], [44], [45], fuzzing [46], [47], [48], vulnerability detection [49], [50], and vulnerability exploitation [51], [52], [53]. PentestGPT [43] and FirmAgent [51] use LLMs as agents to orchestrate penetration testing of general systems and IoT firmware. ChatAFL [52], TitanFuzz [54], and Fuzz4All [48] use LLMs to generate or mutate test inputs for fuzzing. IRIS [45] uses LLMs to infer taint specifications for static vulnerability detection, while EnIGMA [53] equips LLM agents with interactive tools for autonomous vulnerability exploitation. Like these systems, LENS also relies on task-specific information to guide security analysis. However, the information required by existing systems is typically explicit and available, such as source code, protocol grammars, execution traces, or tool outputs. In contrast, our analysis requires exploitability-analysis discipline and evidence-collection guidance, both of which are tacit expert knowledge that is not available in an explicit form. Our work therefore not only performs exploitability analysis, but must also address the problem of obtaining such knowledge to support the analysis.

9. Conclusion

In this paper, we presented LENS, an LLM-based methodology for reliable field-level protocol exploitability analysis. Using LENS, we conducted the first systematic field-level exploitability analysis of the Diameter S6a and Cx interfaces and found that over one quarter of the analyzed fields are exploitable once core-network elements become reachable. Our analysis further uncovered 95 previously unknown vulnerabilities in open-source and commercial EPC/IMS implementations, indicating that many of these protocol-level weaknesses are already present in existing implementations.

References

- [1] Y. Zhang, T. Wan, Y. Yang, H. Duan, Y. Wang, J. Chen, Z. Wei, and X. Li, "Invade the walled garden: Evaluating gtp security in cellular networks," in *2025 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2025, pp. 1159–1177.
- [2] G. Miller and S. Lange, "Bad connection: Uncovering global telecom exploitation by covert surveillance actors," The Citizen Lab, University of Toronto, Citizen Lab Report 192, Apr. 2026, published April 23, 2026. [Online]. Available: <https://citizenlab.ca/research/uncovering-global-telecom-exploitation-by-covert-surveillance-actors/>
- [3] Y. Yang, Y. Zhang, T. Wan, H. Duan, D. Chang, Y. Li, and S. Tang, "Small cell, big risk: A security assessment of 4g lte femtocells in the wild," in *Proceedings of the Network and Distributed System Security Symposium (NDSS)*, 2026.
- [4] V. Fajardo, J. Arkko, J. Loughney, and G. Zorn, "Diameter base protocol," Internet Engineering Task Force (IETF), RFC 6733, Oct. 2012. [Online]. Available: <https://datatracker.ietf.org/doc/rfc6733/>
- [5] 3GPP, "Diameter applications; 3gpp specific codes and identifiers," 3rd Generation Partnership Project (3GPP), Technical Specification TS 29.230, Version 19.3.0, Release 19, Jan. 2026.
- [6] M. Polanyi, "The tacit dimension," in *Knowledge in organisations*. Routledge, 2009, pp. 135–146.
- [7] O. Honovich, U. Shaham, S. Bowman, and O. Levy, "Instruction induction: From few examples to natural language task descriptions," in *Proceedings of the 61st Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, 2023, pp. 1935–1952.
- [8] T. Cai, X. Wang, T. Ma, X. Chen, and D. Zhou, "Large language models as tool makers," in *International Conference on Learning Representations*, vol. 2024, 2024, pp. 54 067–54 089.
- [9] S. Lin, W. Hua, L. Li, Z. Wang, and Y. Zhang, "Ado: Automatic data optimization for inputs in llm prompts," in *Findings of the Association for Computational Linguistics: ACL 2025*, 2025, pp. 26 134–26 146.
- [10] 3GPP, "Evolved packet system (eps); mobility management entity (mme) and serving gprs support node (sgsn) related interfaces based on diameter protocol," 3rd Generation Partnership Project (3GPP), Technical Specification TS 29.272, Version 19.4.0, Release 19, 2026.
- [11] —, "Ip multimedia (im) subsystem cx and dx interfaces; signalling flows and message contents," 3rd Generation Partnership Project (3GPP), Technical Specification TS 29.228, Version 19.2.0, Release 19, Jan. 2026.
- [12] —, "Cx and dx interfaces based on the diameter protocol; protocol details," 3rd Generation Partnership Project (3GPP), Technical Specification TS 29.229, Version 19.1.0, Release 19, 2026.
- [13] Z. Cui, "Research on security vulnerability analysis techniques for key applications in 5g networks," Doctoral Dissertation, Beijing University of Posts and Telecommunications, Aug. 2025. [Online]. Available: <https://doi.org/10.26969/d.cnki.gbydu.2025.000345>
- [14] S. Kwon, S. Park, H. Cho, Y. Park, D. Kim, and K. Yim, "Towards 5g-based iot security analysis against vo5g eavesdropping," *Computing*, vol. 103, no. 3, pp. 425–447, 2021.
- [15] Y. Xu, Z. Zhang, and Z. Liu, "Beyond elicitation: Provision-based prompt optimization for knowledge-intensive tasks," *IEEE Transactions on Audio, Speech and Language Processing*, 2026.
- [16] K. Wang, F. Duan, P. Li, S. Wang, and X. Cai, "Llms know what they need: Leveraging a missing information guided framework to empower retrieval-augmented generation," in *Proceedings of the 31st International Conference on Computational Linguistics*, 2025, pp. 2379–2400.
- [17] T. Yu, S. Zhang, and Y. Feng, "Auto-rag: Autonomous retrieval-augmented generation for large language models," *arXiv preprint arXiv:2411.19443*, 2024.
- [18] 3GPP, "Numbering, addressing and identification," 3rd Generation Partnership Project (3GPP), Technical Specification TS 23.003, Mar. 2026. [Online]. Available: https://www.3gpp.org/ftp/Specs/archive/23_series/23.003/23003-j60.zip
- [19] LENS, "LENS: Artifact," Online. Available: <https://anonymous.4open.science/r/LENS-533C/>, 2026, anonymous GitHub repository artifact, accessed: Jun. 12, 2026.
- [20] Y. Gao, Y. Xiong, X. Gao, K. Jia, J. Pan, Y. Bi, Y. Dai, J. Sun, H. Wang, H. Wang *et al.*, "Retrieval-augmented generation for large language models: A survey," *arXiv preprint arXiv:2312.10997*, vol. 2, no. 1, p. 32, 2023.
- [21] B. T. Kotte, "Analysis and experimental verification of diameter attacks in long term evolution networks," 2016.
- [22] Z. Tan, B. Ding, Z. Zhang, Q. Li, Y. Guo, and S. Lu, "Device-centric detection and mitigation of diameter signaling attacks against mobile core," in *2021 IEEE Conference on Communications and Network Security (CNS)*. IEEE, 2021, pp. 29–37.
- [23] S. Mashukov, "Diameter security: An auditor's viewpoint," *Journal of ICT Standardization*, vol. 5, no. 1, pp. 53–68, 2017.
- [24] S. Holtmanns, I. Oliver, and Y. Miche, "Mobile subscriber profile data privacy breach via 4g diameter interconnection," *Journal of ICT Standardization*, vol. 6, no. 3, pp. 245–262, 2018.
- [25] S. Lee, "Open5gs: Open source implementation for 5g core and epc," [Online]. Available: <https://github.com/open5gs/open5gs>, 2026, version v2.7.7.
- [26] K. S. S. Project, "Kamailio: The open source sip server," [Online]. Available: <https://github.com/kamailio/kamailio>, 2026, version v6.1.3.
- [27] 3GPP, "General Packet Radio Service (GPRS) enhancements for Evolved Universal Terrestrial Radio Access Network (E-UTRAN) access," 3rd Generation Partnership Project (3GPP), Technical Specification TS 23.401, 2026. [Online]. Available: <https://www.3gpp.org/dynareport/23401.htm>
- [28] —, "Non-Access-Stratum (NAS) protocol for Evolved Packet System (EPS); Stage 3," 3rd Generation Partnership Project (3GPP), Technical Specification TS 24.301, 2023. [Online]. Available: <https://www.3gpp.org/dynareport/24301.htm>
- [29] Orange OpenSource, "diafuzzer: Diameter fuzzer," <https://github.com/Orange-OpenSource/diafuzzer>.
- [30] N. Bennett, W. Zhu, B. Simon, R. Kennedy, W. Enck, P. Traynor, and K. R. Butler, "Ransacked: A domain-informed approach for fuzzing lte and 5g ran-core interfaces," in *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, 2024, pp. 2027–2041.
- [31] C. Park, S. Bae, B. Oh, J. Lee, E. Lee, I. Yun, and Y. Kim, "{DoLTEst}: In-depth downlink negative testing framework for {LTE} devices," in *31st USENIX Security Symposium (USENIX Security 22)*, 2022, pp. 1325–1342.
- [32] H. Kim, J. Lee, E. Lee, and Y. Kim, "Touching the untouchables: Dynamic security analysis of the lte control plane," in *2019 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2019, pp. 1153–1168.
- [33] Y. Chen, D. Tang, Y. Yao, M. Zha, X. Wang, X. Liu, H. Tang, and B. Liu, "Sherlock on specs: Building {LTE} conformance tests through automated reasoning," in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 3529–3545.
- [34] A. Al Ishtiaq, S. S. S. Das, S. M. M. Rashid, A. Ranjbar, K. Tu, T. Wu, Z. Song, W. Wang, M. Akon, R. Zhang *et al.*, "Hermes: Unlocking security analysis of cellular network protocols by synthesizing finite state machines from natural language specifications," in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024, pp. 4445–4462.
- [35] K. Tu, A. Al Ishtiaq, S. M. M. Rashid, Y. Dong, W. Wang, T. Wu, and S. R. Hussain, "Logic gone astray: A security analysis framework for the control plane protocols of 5g basebands," in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024, pp. 3063–3080.

- [36] D. Basin, J. Dreier, L. Hirschi, and S. Radomirovic, “A formal analysis of 5g authentication,” in *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*, 2018, pp. 1383–1396.
- [37] M. Akon, T. Yang, Y. Dong, and S. R. Hussain, “Formal analysis of access control mechanism of 5g core network,” in *Proceedings of the 2023 ACM SIGSAC conference on computer and communications security*, 2023, pp. 666–680.
- [38] M. Akon, M. Toufikuzzaman, and S. R. Hussain, “From control to chaos: A comprehensive formal analysis of 5g’s access control,” in *2025 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2025, pp. 1081–1100.
- [39] Y. Yang, G. Yang, Y. Li, M. Huang, Z. Shen, I. Karim, R. Sasse, D. Basin, E. Bertino, J. Weng *et al.*, “{AKMA+}: Security and {Privacy-Enhanced} and {Standard-Compatible}{AKMA} for 5g communication,” in *34th USENIX Security Symposium (USENIX Security 25)*, 2025, pp. 5327–5345.
- [40] Y. Dong, T. Yang, A. Al Ishtiaq, S. M. M. Rashid, A. Ranjbar, K. Tu, T. Wu, M. S. Mahmud, and S. R. Hussain, “Corecrisis: Threat-guided and context-aware iterative learning and fuzzing of 5g core networks,” in *34th USENIX Security Symposium (USENIX Security 25)*, 2025, pp. 5287–5306.
- [41] D. Klischies, D. Goos, D. Hirsch, A. Milburn, M. Muench, and V. Moonsamy, “Basebridge: Bridging the gap between over-the-air and emulation testing for cellular baseband firmware,” in *2025 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2025, pp. 1101–1119.
- [42] T. D. Hoang, T. Oh, C. Park, I. Yun, and Y. Kim, “Llfuzz: An over-the-air dynamic testing framework for cellular baseband lower layers,” in *34th USENIX Security Symposium (USENIX Security 25)*. USENIX Association, 2025, pp. 5267–5286.
- [43] G. Deng, Y. Liu, V. Mayoral-Vilches, P. Liu, Y. Li, Y. Xu, T. Zhang, Y. Liu, M. Pinzger, and S. Rass, “PentestGPT: Evaluating and harnessing large language models for automated penetration testing,” in *33rd USENIX Security Symposium (USENIX Security 24)*. USENIX Association, 2024, pp. 847–864.
- [44] B. Singer, K. Lucas, L. Adiga, M. Jain, L. Bauer, and V. Sekar, “Incalmo: An autonomous LLM-assisted system for red teaming multi-host networks,” in *2026 IEEE Symposium on Security and Privacy (SP)*, 2026, to appear.
- [45] Z. Li, S. Dutta, and M. Naik, “IRIS: LLM-assisted static analysis for detecting security vulnerabilities,” in *International Conference on Learning Representations (ICLR)*, 2025.
- [46] X. Song, L. Pei, J. Wu, Y. Zeng, G. He, C. Zuo, X. Liu, Q. Zhao, and S. Guo, “Protocolguard: Detecting protocol non-compliance bugs via LLM-guided static analysis and dynamic verification,” in *Proceedings 2026 Network and Distributed System Security Symposium (NDSS)*. Internet Society, 2026.
- [47] X. Ma, L. Luo, and Q. Zeng, “From one thousand pages of specification to unveiling hidden bugs: Large language model assisted fuzzing of matter IoT devices,” in *33rd USENIX Security Symposium (USENIX Security 24)*. USENIX Association, 2024, pp. 4783–4800.
- [48] C. S. Xia, M. Paltenghi, J. L. Tian, M. Pradel, and L. Zhang, “Fuzz4All: Universal fuzzing with large language models,” in *Proceedings of the 46th IEEE/ACM International Conference on Software Engineering (ICSE)*. ACM, 2024, pp. 126:1–126:13.
- [49] S. Ullah, M. Han, S. Pujar, H. Pearce, A. Coskun, and G. Stringhini, “Llms cannot reliably identify and reason about security vulnerabilities (yet?): A comprehensive evaluation, framework, and benchmarks,” in *2024 IEEE symposium on security and privacy (SP)*. IEEE, 2024, pp. 862–880.
- [50] A. Lekssays, H. Mouhcine, K. Tran, T. Yu, and I. Khalil, “{LLMxCPG}:{Context-Aware} vulnerability detection through code property {Graph-Guided} large language models,” in *34th USENIX Security Symposium (USENIX Security 25)*, 2025, pp. 489–507.
- [51] J. Ji, C. Zhang, S. Gan, L. Jian, H. Liu, T. Liu, L. Zheng, and Z. Jia, “FirmAgent: Leveraging fuzzing to assist LLM agents with IoT firmware vulnerability discovery,” in *33rd Annual Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2026.
- [52] R. Meng, M. Mirchev, M. Böhme, and A. Roychoudhury, “Large language model guided protocol fuzzing,” in *31st Annual Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2024.
- [53] T. Abramovich, M. Udeshi, M. Shao, K. Lieret, H. Xi, K. Milner, S. Jancheska, J. Yang, C. E. Jimenez, F. Khorrami *et al.*, “EnIGMA: Interactive tools substantially assist LM agents in finding security vulnerabilities,” *arXiv preprint arXiv:2409.16165*, 2024.
- [54] Y. Deng, C. S. Xia, H. Peng, C. Yang, and L. Zhang, “Large language models are zero-shot fuzzers: Fuzzing deep-learning libraries via large language models,” in *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. ACM, 2023, pp. 423–435.

Appendix A. Open Science

To support reproducibility, we provide an anonymized artifact at [19]. All prompts, evaluation data, and protocol-level PoCs used in this work are publicly available in the artifact.

Appendix B. Additional Evaluation Results

TABLE 14: End-to-End effectiveness of LENS on S6a and Cx.

Model	Interface	Recall (%)	Precision (%)	Accuracy (%)
GPT	S6a	94.00±8.94	90.63±6.01	92.00±5.70
	Cx	98.00±4.47	87.73±7.11	92.00±6.71
GLM	S6a	94.00±5.48	69.83±7.96	76.00±7.42
	Cx	94.00±5.48	90.55±6.45	92.00±5.70
Claude	S6a	96.00±5.48	83.08±4.68	88.00±2.74
	Cx	100.00±0.00	89.93±8.27	94.00±5.48
Gemini	S6a	98.00±4.47	77.82±3.19	85.00±3.54
	Cx	94.00±5.48	93.38±10.17	93.00±5.70

TABLE 15: Per-field correctness of LENS across five runs.

Model	5/5	4/5	3/5	2/5	1/5	0/5
GPT	30	7	2	0	0	1
GLM	29	2	3	2	2	2
Claude	31	4	2	2	1	0
Gemini	29	6	2	1	1	1

Note: Each column reports the number of fields correctly analyzed in exactly k of five runs (e.g., 5/5 means correct in all five runs).

TABLE 16: Message-level exploitability results.

No.	Interface	Message	Receiver	Receiver-Side Operation	Fields	PoCs	Effect Categories
1	S6a	ULR	MME	Report supported feature information for location update	1	1	C3
2	S6a	AIR	MME	Report supported feature information for S6a authentication	1	1	C3
3	S6a	NOR	MME	Report supported feature information for S6a notification	1	1	C3
4	S6a	PUR	MME	Report supported feature information for UE purge	1	1	C3
5	S6a	IDR	MME	Report the UE's current state	2	3	C5
6	S6a	IDR	MME	Report the UE's location information	4	4	C5
7	S6a	DSR	MME	Update selected subscriber/service data	6	8	C1, C2
8	S6a	IDR	MME	Update the UE's aggregate data-rate limit	6	8	C2
9	S6a	IDR	MME	Update the UE's APN/PDN connectivity configuration	18	21	C1, C2
10	S6a	RSR	MME	Update the UE's APN/PDN connectivity configuration	3	4	C1, C2
11	S6a	IDR	MME	Update the UE's CSG connectivity configuration	2	2	C1
12	S6a	IDR	MME	Update the UE's LCS configuration	11	11	C2
13	S6a	RSR	MME	Update the UE's LCS configuration	2	2	C2
14	S6a	IDR	MME	Update the UE's MDT configuration	27	27	C2, C4, C5
15	S6a	RSR	MME	Update the UE's MDT configuration	15	15	C2, C4, C5
16	S6a	IDR	MME	Update the UE's ProSe configuration	3	3	C2
17	S6a	RSR	MME	Update the UE's ProSe configuration	2	2	C2
18	S6a	CLR	MME	Update the UE's registration state	1	2	C1
19	S6a	IDR	MME	Update the UE's subscribed QoS profile	4	4	C2
20	S6a	IDR	MME	Update the UE's subscriber profile	23	23	C1, C2, C4
21	S6a	RSR	MME	Update the UE's subscriber profile	10	10	C1, C2, C4
22	S6a	IDR	MME	Update the UE's WLAN offload permission	2	2	C1
23	S6a	CLR	HSS	Report supported feature information for location cancellation	1	1	C3
24	S6a	RSR	HSS	Report supported feature information for S6a reset	1	1	C3
25	S6a	DSR	HSS	Report supported feature information for subscriber-data deletion	1	1	C3
26	S6a	IDR	HSS	Report supported feature information for subscriber-data insertion	1	1	C3
27	S6a	AIR	HSS	Report the UE's authentication vectors	4	5	C1, C3
28	S6a	ULR	HSS	Report the UE's subscriber profile	2	2	C3, C5
29	S6a	PUR	HSS	Update the UE's purged status	1	1	C2
30	S6a	NOR	HSS	Update the UE's reachability information	1	1	C4
31	S6a	ULR	HSS	Update the UE's serving-MME information	2	3	C1, C3
32	S6a	NOR	HSS	Update the UE-to-PDN-GW association	1	1	C1
33	Cx	MAR	S-CSCF	Report supported feature information for IMS authentication	1	1	C3
34	Cx	UAR	S-CSCF	Report supported feature information for IMS authorization	1	1	C3
35	Cx	SAR	S-CSCF	Report supported feature information for server assignment	1	1	C3
36	Cx	LIR	S-CSCF	Report supported feature information for user-location query	1	1	C3
37	Cx	PPR	S-CSCF	Update the UE's IMS charging configuration	2	2	C1
38	Cx	PPR	S-CSCF	Update the UE's IMS authentication data	9	9	C1
39	Cx	RTR	S-CSCF	Update the UE's IMS registration state	6	6	C1, C3
40	Cx	PPR	S-CSCF	Update the UE's IMS service profile	2	2	C1
41	Cx	PPR	S-CSCF	Update the UE's WebRTC configuration	2	2	C1
42	Cx	PPR	HSS	Report supported feature information for profile update	1	1	C3
43	Cx	RTR	HSS	Report supported feature information for registration termination	1	1	C3
44	Cx	MAR	HSS	Report the UE's IMS authentication vectors	5	5	C1, C3
45	Cx	UAR	HSS	Report the UE's IMS authorization result	2	3	C1, C3
46	Cx	SAR	HSS	Report the UE's IMS service profile	1	1	C3
47	Cx	LIR	HSS	Report the UE's serving S-CSCF information	2	3	C3, C5
48	Cx	SAR	HSS	Update the UE's restoration information	2	2	C1
49	Cx	SAR	HSS	Update the UE's serving S-CSCF information	5	9	C1, C3
Overall	—	—	—	49 message-level scenarios	204	222	—

Note: This table provides the message-level view discussed in Section 5.1. The 204 validated fields are grouped by Diameter message, receiver, and receiver-side operation. Fields sharing these three properties constitute the same message-level scenario, yielding 49 scenarios in total. Fields and PoCs denote the numbers of validated exploitable fields and corresponding protocol-level PoCs, respectively. Effect categories C1–C5 follow Table 11.

TABLE 17: Detailed results of the implementation-level assessment.

For CID, C1: service disruption; C2: service degradation; C3: information leakage; C4: battery depletion; C5: subscriber tracking;
For Affected Impl., Impl.: implementation; O1: Open5GS; O2: Kamailio; C1: Commercial A; C2: Commercial B; ●: affected; ○: not affected.

(a) S6a Interface

PID	Diameter Fields	Value	CID	Affected Impl.	
				O1	C1
1	CLR: Cancellation-Type	<i>MME_UPDATE_PROCEDURE</i>	C1	●	●
2	CLR: Cancellation-Type	<i>SUBSCRIPTION_WITHDRAWAL</i>	C1	●	●
3	ULR: ULR-Flags	<i>Initial-Attach-Indicator</i>	C1	●	●
4	ULR: ULR-Flags	<i>Skip Subscriber Data</i>	C3	●	●
5	AIR: Requested-EUTRAN-Authentication-Info	<i>1</i>	C3	●	●
6	IDR: IDR-Flags	<i>EPS User State Request</i>	C5	●	●
7	IDR: IDR-Flags	<i>EPS Location Information Request</i>	C5	●	○
8	DSR: Context-Identifier	<i>Non-Default APN</i>	C1	○	●
9	DSR: DSR-Flags	<i>PDN subscription contexts Withdrawal</i>	C1	○	●
10	DSR: DSR-Flags	<i>MSISDN Withdrawal</i>	C1	○	●
11	IDR: Subscription-Data.APN-OI-Replacement	<i><Attacker>.mnc<MNC>.mcc<MCC>.gprs</i>	C1	○	●
12	IDR: Subscription-Data.APN-Configuration-Profile	<i>Null</i>	C1	○	●
13	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. All-APN-Configurations-Included-Indicator	<i>All-APN_CONFIGURATIONS_INCLUDED</i>	C1	○	●
14	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. APN-OI-Replacement	<i><Attacker>.mnc<MNC>.mcc<MCC>.gprs</i>	C1	○	●
15	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. Context-Identifier	<i>Default PDN(1)</i>	C1	○	●
16	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. Context-Identifier	<i>Non-Default PDN (2)</i>	C1	○	●
17	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. MIP6-Agent-Info	<i>1.1.1.1</i>	C1	○	●
18	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. PDN-GW-Allocation-Type	<i>STATIC</i>	C1	○	●
19	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. Served-Party-IP-Address	<i>1.1.1.1</i>	C1	○	●
20	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. Service-Selection	<i>internet</i>	C1	○	●
21	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. Service-Selection	<i>ims</i>	C1	○	●
22	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. VPLMN-Dynamic-Address-Allowed	<i>NOTALLOWED</i>	C1	○	●
23	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. SIPTO-Local-Network-Permission	<i>NOTALLOWED</i>	C1	○	●
24	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. SIPTO-Permission	<i>Null</i>	C1	○	●
25	IDR: Subscription-Data.Regional-Subscription-Zone-Code	<i>0102</i>	C1	○	●
26	IDR: Subscription-Data.Subscriber-Status	<i>OPERATOR_DETERMINED_BARRING</i>	C1	○	●
27	IDR: Subscription-Data.Access-Restriction-Data	<i>WB-E-UTRAN Not Allowed</i>	C1	○	●
28	IDR: Subscription-Data.HPLMN-ODB	<i>1</i>	C1	○	●
29	IDR: Subscription-Data.Operator-Determined-Barring	<i>All Packet Oriented Services Barred</i>	C1	○	●
30	IDR: Subscription-Data.CSG-Subscription-Data.Expiration-Date	<i>2026-06-11 23:59:59</i>	C1	○	●
31	IDR: Subscription-Data.CSG-Subscription-Data.CSG-Id	<i>0x00000020</i>	C1	○	●
32	PUR: User-Name	<i>IMSI</i>	C2	○	●
33	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. PDN-Type	<i>IPv6</i>	C1	○	●
34	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. PDN-Type	<i>IPv4v6</i>	C2	○	●
35	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. EPS-Subscribed-QoS-Profile	<i>QCI_9</i>	C2	○	●
36	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. EPS-Subscribed-QoS-Profile.Allocation-Retention-Priority	<i>15</i>	C2	○	●
37	IDR: Subscription-Data.AMBR.Max-Requested-Bandwidth-DL	<i>1bps</i>	C2	○	●
38	IDR: Subscription-Data.AMBR.Max-Requested-Bandwidth-UL	<i>1bps</i>	C2	○	●
39	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. AMBR.Max-Requested-Bandwidth-DL	<i>1bps</i>	C2	○	●
40	IDR: Subscription-Data.APN-Configuration-Profile.APN-Configuration. AMBR.Max-Requested-Bandwidth-UL	<i>1bps</i>	C2	○	●
41	IDR: Subscription-Data.Subscribed-Periodic-RAU-TAU-Timer	<i>2s</i>	C4	○	●

TABLE 17: Detailed results of the implementation-level assessment. Continued.

(b) Cx Interface

PID	Diameter Fields	Value	CID	Affected Impl.		
				O2	C1	C2
42	RTR: User-Name	000001234567890@ims.mnc000.mcc000.3gppnetwork.org	C3	○	●	○
43	RTR: Associated-Identities	000001234567890@ims.mnc000.mcc000.3gppnetwork.org	C1	●	●	○
44	RTR: Public-Identity	sip:000001234567890@ims.mnc000.mcc000.3gppnetwork.org	C1	●	●	●
45	SAR: Server-Name	sip:scscf.ims.system.com	C1	●	●	●
46	SAR: Server-Assignment-Type	REGISTRATION	C1	●	●	○
47	SAR: Server-Assignment-Type	RE_REGISTRATION	C1	●	●	○
48	SAR: Server-Assignment-Type	UNREGISTERED_USER	C3	○	●	●
49	SAR: Server-Assignment-Type	USER_DEREGISTRATION	C1	○	●	●
50	SAR: Server-Assignment-Type	ADMINISTRATIVE_DEREGISTRATION	C1	○	●	●
51	MAR: 3GPP-SIP-Number-Auth-Items	Digest-AKAv1-MD5	C3	●	●	●
52	UAR: User-Authorization-Type	REGISTRATION	C3	●	●	●
53	UAR: User-Authorization-Type	REGISTRATION_AND_CAPABILITIES	C3	○	●	○
54	SAR: User-Data-Already-Available	USER_DATA_NOT_AVAILABLE	C3	●	●	●
55	LIR: User-Authorization-Type	REGISTRATION	C3	●	●	●
56	LIR: User-Authorization-Type	REGISTRATION_AND_CAPABILITIES	C3	○	●	○
57	LIR: Originating-Request	ORIGINATING	C5	●	●	●
58	PPR: 3GPP-SIP-Auth-Data-Item	Any String	C1	○	●	●
59	PPR: Cx-User-Data	Forged User Profile XML	C1	○	●	●
60	RTR: Deregistration-Reason.Reason-Code	PERMANENT_TERMINATION	C1	○	●	●
61	RTR: Deregistration-Reason.Reason-Info	Any String	C1	○	●	○
62	SAR: SCSCF-Restoration-Info.Path	sip:term@192.168.5.103:5060	C1	○	●	●
63	SAR: SCSCF-Restoration-Info.Contact	sip:75ba167d-7228-40d0-a1aa-54d9f5b9bf1@1.1.1.1:1111	C1	○	●	●
64	SAR: Wildcarded-Public-Identity	sip:000001234567890@ims.mnc000.mcc000.3gppnetwork.org	C1	○	●	○

TABLE 18: Generalizability results across non-Diameter protocols.

No.	Protocol	Application Domain	Analyzable Fields	Detected Fields	New Fields	Confirmed New Fields (%)	Tested Implementation	Version
1	SIP	VoIP Communication	99	17	10	8 (80.00%)	Kamailio	6.2.0-dev0
2	BGP	Internet Routing	78	22	15	12 (80.00%)	FRRouting	10.3.1
3	MQTT	IoT Messaging	67	39	20	16 (80.00%)	Mosquitto	2.1.2
4	DHCP	Network Configuration	27	24	10	8 (80.00%)	Suricata/Snort3	3.11.1.0
5	RADIUS	Network Authentication	59	12	9	8 (88.89%)	FreeRADIUS	3.2.8
6	HTTP/2	Web Infrastructure	34	24	2	2 (100.00%)	Nginx	1.27.x
7	DNS	Internet Infrastructure	27	15	1	1 (100.00%)	DnsMasq	2.90
8	SNMP	Network Management	24	3	0	0 (N/A)	Net-SNMP	5.10.pre2
9	CCSDS-SLE	Space Communication	46	26	25	22 (88.00%)	CCSDS	1.1.0
10	OCI	Container Runtime	54	23	11	7 (63.64%)	Docker Desktop	4.58.0
11	Wayland	Desktop Graphics	50	18	15	12 (80.00%)	Weston/Sway	13.0.0 / 1.9
12	Modbus	Industrial Control	39	15	5	3 (60.00%)	OpenPLC	v3
13	FUSE	File-System Interface	34	9	5	3 (60.00%)	S3fs-Fuse	1.97
14	RTSP	Multimedia Streaming	73	5	3	2 (66.67%)	live555	2026-03-23
15	AMQP	Enterprise Messaging	69	11	9	7 (77.78%)	ActiveMQ	2.37.0
16	D-Bus	Inter-Process Communication	77	16	10	7 (70.00%)	DBus-Daemon	1.12.20
Total			857	279	150	118 (78.67%)		

TABLE 19: Comparison with DiaFuzzer-based fuzzing.

Implementation	Interface	LENS		DiaFuzzer-Based Fuzzing	
		Confirmed Fields	Confirmed PoCs	PoC Manipulations Generated	PoC Effects Detected
Open5GS	S6a	4	7	7	7 (100.00%)
Kamailio	Cx	9	10	10	7 (70.00%)
Commercial A	S6a	35	40	40	12 (30.00%)
Commercial A	Cx	16	23	23	12 (52.17%)
Commercial B	Cx	15	15	15	7 (46.67%)
Overall	–	51	64	64	26 (40.63%)

Note: A field may correspond to multiple PoCs when different field values cause distinct security effects. PoC Manipulations Generated counts LENS-confirmed PoCs for which DiaFuzzer-based fuzzing generates the corresponding field-value manipulation, while PoC Effects Detected counts PoCs whose security effects are also automatically detected by the fuzzer. The Overall row reports deduplicated counts across implementations.